IS Audit & Control

Abdul-Rahman Mahmood
Assistant Professor, Computer Science, FAST-NU

abdulrahman@nu.edu.pk
alphapeeler.sf.net/pubkeys/pkey.htm
pk.linkedin.com/in/armahmood
bqb-tsid-asp
alphapeeler
alphapeeler
armahmood786
http://alphapeeler.sf.net/
reddit.com/user/alphapeeler
www.flickr.com/alphapeeler
http://alphapeeler.tumblr.com
armahmood786@jabber.org
alphapeeler@aim.com
abdulmahmood-sss
alphapeeler@icloud.com
pinterest.com/alphapeeler

Auditing Unix and Linux Operating Systems

Part 4

Objectives

- • Network security and controls
- • Audit logs
- • Security monitoring and general controls
- • Tools and resources for enhancing your *nix audits

Network security and controls

- 33. Review and evaluate the use of .netrc files.
  - The .netrc files are used to automate logons. If a confidential password is placed in one of these files, the password may be exposed to other users on the system.
  - find / -name '.netrc' -print -exec more {} \;
- 34. Ensure that a legal warning banner is displayed when a user connects to the system.
  - "You're not allowed to use this system unless you've been authorized to do so."
  - located in files such as /etc/issue and /etc/sshd_config (or /etc/ openssh/sshd_config).

Network security and controls

- 35. Evaluate the use of modems on the server.
  - Modems bypass corporate perimeter security (such as firewalls) and allow direct access to the machine from outside the network.
  - If they are used, alternative mechanisms for allowing external access to the machine should be investigated. If a dial-in modem is deemed truly necessary, consider implementing compensating controls such as dial-back to trusted numbers (that is, when a call is received, the machine hangs up and dials back to a trusted number) and authentication.

Audit Logs

Audit Logs

- 36. Review controls for preventing direct "root" logins.
  - Review the **wtmp** log (/usr/adm/wtmp, /var/adm/wtmp, or /etc/wtmp) to verify that there are no direct "root" logins.
  - Review settings for preventing direct "root" logins via telnet and rlogin.
    - The file /etc/default/login can be used to disable direct "root" logins on Solaris machines.
    - On Linux and HP systems, the /etc/securetty file can be used to prevent direct logins as "root."
  - Review settings for preventing direct "root" logins via SSH.(**/etc/sshd_config** or**/etc/openssh/sshd_config**). Look for the **PermitRootLogin** parameter.

Audit Logs

- 37. Review su / sudo command logs to ensure they are logged with date, time, user who typed the command.
  - The su log will be at /usr/adm/sulog, /var/adm/sulog, /var/log/auth.log or /etc/default/su
- 38. Evaluate syslog to ensure adequate info is captured.
  - /etc/syslog. conf determines where each message type is routed (to a filename, to a console, and/or to a user).
  - Common syslog facilities (system function types):
    - **kern** Kernel
    - **user** Normal user processes
    - **mail** Mail system
    - **lpr** Line printer system
    - **auth** Authorization systems (programs that ask for usernames and passwords)
    - **daemon** System daemons
    - **cron** cron daemon

Audit Logs

- 39. Evaluate the security and retention of the wtmp log, sulog, syslog, and any other relevant audit logs.
  - Perform a ls -l command on those files. They usually should be writable only by "root" or some other system account.
- 40. Evaluate security over the utmp file.
  - The utmp log keeps track of who is currently logged into the system and includes information regarding what terminals from which users are logged in. By changing the terminal name in this file to that of a sensitive file, an attacker can get system programs that write to user terminals to overwrite the target file. This would cause this sensitive file to be corrupted.
  - /etc/utmp (UNIX) or /var/run/utmp (Linux). File should be owned by "root".

Security Monitoring and General Controls

Security Monitoring & General Controls

- 41. Review and evaluate system administrator procedures for monitoring the state of security on the system.
- Following are 4 primary levels of monitoring:
  - Network vulnerability scanning: The most important security monitoring. It monitors for potential vulnerabilities that could allow someone who has no business being on the system either to gain access to the system or disrupt the system.
  - Host-based vulnerability scanning: Scanning for vulnerabilities that would allow someone who's already on the system to escalate his or her privileges (such as exploit the "root" account), obtain inappropriate access to sensitive data (owing to poorly set file permissions, for example), or disrupt the system. This type of scanning generally is more important on systems with many nonadministrative end users.

Security Monitoring & General Controls

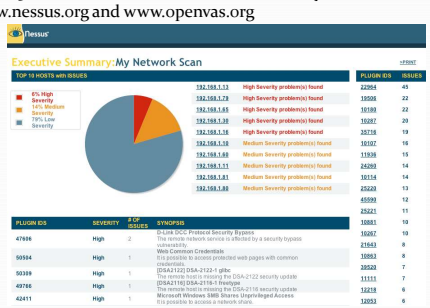
- Intrusion detection: Detects unauthorized entry (or attempts at unauthorized entry) into the system. Baseline monitoring tools (such as Tripwire) can be used to detect changes to critical files, and log-monitoring tools can be used to detect suspicious activities via the system logs.
- Intrusion prevention: Detects an attempted attack and stops the attack before it compromises the system. Examples include host Intrusion Prevention System (IPS) tools and network-based IPS tools such as Tipping Point.

Security Monitoring & General Controls

- 42. If you are auditing a larger Unix/Linux environment (as opposed to one or two isolated systems), determine whether a standard build exists for new systems and whether that baseline has adequate security settings. Consider auditing a system freshly created from the baseline.
- 43. Perform steps from Data Center as they pertain to the system you are auditing.
  - Physical security • Environmental controls • Capacity planning • Change management • System monitoring • Backup processes • Disaster recovery planning

Tools and Technology

- Nessus: Network vulnerability scanner (1998) : most advanced and popular open-source network vulnerability-assessment tool. Beginning with V3.0, It is now closed-source and owned by Tenable Security. www.nessus.org and www.openvas.org



Tools and Technology

- **NMAP** : check open ports on a server without running an all out vulnerability scanner such as Nessus, perhaps to test the rules of a host-based firewall. See www.insecure.org/nmap.
- **Chkrootkit :** Chkrootkit is designed to identify both known rootkits running on a system and "suspicious" files or processes.
- **Crack and John the Ripper**
  - For checking the strength of user-chosen passwords
- **Tiger and TARA**
  - host-based vulnerability scanning tools
- **Shell/Awk/etc**
  - not a tool in the same sense
  - chop up and process text output from commands. Much of the required information to perform the steps in this audit program could be obtained by the use of a shell script.
- **Refer to book for details of all above listed tools …**